The Islamia University of Bahawalpur
Department of Information Technology

INFT-4041 · BSIT · 5th Semester · Fall 2026

E-Commerce Application Development

Chapter

22

Social, Legal and Ethical Issues

Part VI — Reach, Law and Practice

Taught in	Week 16
Laboratory	Project presentations
Assessment	**Project due; presentations**

This is a class extract. It is *Chapter 22* of the unified handout, printed on its own so that a week's reading is a week's reading. Page numbers restart at 1 and are local to this extract; chapter, figure and table numbers are the ones the full volume gives them, so a reference you follow here lands in the same place there.

Cross-references to other chapters print as their numbers in the full volume. For the whole course in one file — front matter, the HEC tracing table, all twenty-three chapters and all seven appendices — see `ECAD_Fall2026_Handout.pdf`.

Dr. Mustafa Hameed · Department of Information Technology

Generated from `parts/` by `makechapters.py`; do not edit this PDF's source by hand

Chapter 22

Social, Legal and Ethical Issues

Learning Outcomes

By the end of this chapter you will be able to:

- **Name** the Pakistani instruments that bind an online shop, and **state** what each one governs.
- **Explain** what makes an online contract enforceable, and **identify** where consumer law actually comes from here.
- **Recognise** a dark pattern, including ones this course produced by accident.
- **Assess** what personal data a shop holds, and **justify** keeping or discarding each kind.
- **Argue** a professional position on a request you are asked to implement.

Before You Start

Chapter 9: what the shop records about visitors who never buy. Chapter 12: the totals pipeline and what moving a line does. Chapter 16: PECA 2016, and what the shop exposed. Chapter 18: what a refund does and does not do.

Key Terms in This Chapter

electronic contract • Electronic Transactions Ordinance 2002 • PECA 2016 • E-Commerce Policy 2019 • consumer protection • provincial jurisdiction • personal data • data minimisation • retention • dark pattern • accessibility • WCAG • professional responsibility

22.1 What Makes an Online Order a Contract

A shop takes money from strangers it never meets, on the strength of a click. The question of why that click binds anybody is older than the software and is answered by one instrument.

Electronic Transactions Ordinance 2002

Pakistan's **Electronic Transactions Ordinance 2002** gives legal recognition to electronic documents, records and signatures: a contract is not void merely because it was made electronically, and an electronic record satisfies a legal requirement for writing.

Without it, every order in this course would be unenforceable. With it, the click is a contract — which cuts both ways, because it is also what makes your shop's published terms binding on *you*.

Practical consequence: the order record is the contract. That is why Chapter 10 copies the price, the address and the totals into the order rather than pointing at the catalogue, and why Chapter 18 treats the order history as the thing a dispute is settled from. Those were engineering decisions in those chapters; here they are the reason they were the right ones.

22.2 The Instruments, and What Each Governs

Instrument	Governs	Why it reaches you
Electronic Transactions Ordinance 2002	Electronic records, signatures, contracts	Your orders are enforceable
PECA 2016	Offences involving information systems	Unauthorised access is criminal — Chapter 16
E-Commerce Policy of Pakistan 2019	Policy direction: consumer protection, payments, taxation, data	The framework the rest is built under
Provincial consumer protection Acts	Goods, services, redress	**Not federal** — see below
Sales tax law, administered by FBR	Registration, collection, returns	Chapter 11's rate and rules

Two things about Pakistani law that surprise students

First: consumer protection is provincial, not federal. Punjab, Sindh, Khyber Pakhtunkhwa and Balochistan each have their own consumer protection legislation, with their own authorities and their own procedures. A shop in Bahawalpur selling to Karachi may be answerable under a different Act from the one it was set up under, and "the consumer protection law" is not a thing that exists.

Second: Pakistan has no comprehensive data protection Act in force. A Personal Data Protection Bill has been in draft for years. What this means in practice is **not** that there are no obligations — contract, the E-Commerce Policy, sectoral rules from the State Bank, and the plain law of confidence all reach — but that *the law is not what will stop you doing something stupid with a customer list.* Your own judgement is, and that is an uncomfortable position to be in rather than a comfortable one.

Both of these can change, and the second is likely to. Check the current position before advising anybody. What this chapter teaches is how to ask, not what the answer was in 2026.

22.3 What Your Shop Already Knows About People

Before any question of obligation, a question of fact: what is in there? This course has already produced the answer, in pieces.

An inventory, from this course's own measurements

- **645 session rows on a shop with no customers** (Chapter 9) — addresses, timestamps and a currency, for visitors who were mostly robots, kept for 24 hours by a clock rather than discarded on departure.
- **An address, a telephone number and an email** on every order, copied and kept permanently, for guests who never created an account (Chapter 10).
- **A complete purchase history per named person**, reachable in two clicks from the admin panel (Chapter 18).
- **An IP address on every customer row**, written at registration and never updated or removed.

- **A PHP error log, readable by anyone over HTTP** before Chapter 16's hardening — and a PHP error log can contain the contents of the request that failed, which on a checkout is somebody's address.
- **Uploaded files in a web-served directory** (Chapter 7), protected by an unguessable name.

Not one of those was a decision. Every one is a default. The shop collects them because the software does, and it keeps them because nothing deletes them.

Three questions worth asking of each

1. **Why do we have this?** If the answer is "it came with the software", that is not an answer, and the thing to find out is what breaks if it goes.
2. **How long do we need it?** An order is an accounting record and has a statutory life. A session row from a crawler has none. They are not the same object and should not have the same fate.
3. **What happens if it leaks?** Rank by that, not by volume. The session table is large and dull; the order table is small and is somebody's home address next to what they bought.

Data minimisation is not a legal doctrine you are importing. It is the engineering observation that you cannot lose what you did not keep, and it is free at design time and expensive afterwards.

22.4 Dark Patterns, Including the Ones We Built

Dark pattern

A **dark pattern** is an interface that leads a user to do something they did not intend and would not have chosen, by exploiting how they read rather than by lying to them. Each element is usually true. The arrangement is the deception.

Three from this handout, two of them accidental

1. Charging tax on a discount the customer never received. Chapter 12 measured it: moving the coupon line after the tax line changed the customer's bill from 770.16 to 784.20. Every line was correct and the total added up. **Nobody designed this as a deception — it is one integer in an admin field** — and a shop that did it deliberately would be indistinguishable from a shop that did it by accident. That is precisely why the arithmetic in Chapter 11 and Chapter 12 is somebody's professional responsibility and not a detail.

2. Removing the confirmation screen to raise conversion. Chapter 10 measured it as 28% of the checkout's time, and listed it as the one step not to remove. Removing it does raise completed orders. It raises them by taking the last moment at which a customer sees what they are agreeing to pay.

3. Optimising a cash-on-delivery checkout for completion. Chapter 13 showed that an unverified COD order is a liability, and that confirming orders by telephone is the most profitable step in the pipeline. Advice imported from prepaid markets — remove every step, reduce friction — produces more unwanted orders, and the customer who refuses at the door was helped into an order they did not want.

A test you can apply before writing the code

Would you be comfortable explaining this arrangement to the customer it affects, in one sentence, out loud?

- "We put the discount before the tax so you pay tax only on what you actually pay." Comfortable.
- "We put the discount after the tax so you pay us an extra 1.8%." Not comfortable. Same software, one integer apart.
- "We show you the total before you pay." Comfortable.
- "We removed that screen because fewer people stopped." Not.

The test is not a substitute for law and does not need to be. It is faster than law, it applies before the code is written, and it has never once in this course disagreed with the right answer.

22.5 Accessibility, Which Is Not Optional and Is Usually Skipped

Four things that cost nothing at build time

Chapter 8 rebuilt a theme without once mentioning the customers who cannot see it. That omission is normal and is a mistake.

1. **Every image has alt text**, and a product photograph's alt text is the product's name — which the shop already has.
2. **Every form field has a label** tied to it, not a placeholder pretending to be one. A placeholder disappears when typing starts, which is exactly when a confused customer needs it.
3. **Colour is never the only signal.** "Out of stock" in red is invisible to a large minority of men.
4. **The checkout works from the keyboard alone.** Try it. It takes four minutes and it is the only one of these four that usually fails.

All four are cheaper than page weight was in Chapter 8, and unlike page weight they cannot be retrofitted by minifying anything. A shop that cannot be used by somebody with a screen reader has excluded a customer who had money and wanted to spend it, which is a commercial fact before it is an ethical one.

22.6 Being Asked to Do Something You Should Not

Four requests you will receive, and an answer to each

- **"Store the card number so customers need not retype it."** No — and the reason is not squeamishness: it moves the shop from PCI DSS SAQ-A to SAQ-D (Chapter 14), which is hundreds of requirements and an audit. *Offer instead:* the provider's own tokenisation, which gives the same convenience and keeps the number where it is already somebody's job to protect.
- **"Email our customer list to this marketing company."** Ask what the customers were told when they gave it, and whether that covers this. If nobody knows, the answer is no. *Offer instead:* send the campaign yourself, which keeps the list where the promise was made.

- **"Delete these orders, they're embarrassing."** No. They are accounting records and Chapter 18 showed they are also what a dispute is settled from. *Offer instead:* a status, a note, and a report that excludes them — which is what was actually wanted.
- **"Check whether our competitor's site has the same vulnerability."** No, and say why plainly: that is unauthorised access to an information system, it is an offence under **PECA 2016**, and no commercial reason changes that. *Offer instead:* check your own, which is what Chapter 16 did.

In every case the answer has the same shape: say no once and clearly, give the reason in terms of consequence rather than of principle, and offer the nearest thing you can do. A refusal with no alternative gets overruled by somebody who will not refuse.

Common Pitfalls

- **Assuming there is one national consumer protection law.** There is not; it is provincial.
- **Assuming no data protection Act means no obligations.** It means the law will not stop you, which is worse.
- **Treating a legal rate or rule as permanent.** Check it against the current instrument before advising anybody.
- **Keeping data because the software collected it.** That is not a reason, and it is not a defence.
- **Ranking data risk by volume** rather than by what a leak would do.
- **Building a dark pattern by accident**, which is what moving one integer did in Chapter 12.
- **Leaving accessibility until after launch**, when it cannot be retrofitted cheaply.
- **Refusing a request without offering an alternative.**
- **Testing any system you do not own** (Chapter 16).

Try It Yourself: Audit your own shop as though it were somebody else's

```
# --- 1. Inventory what you hold about people --------------------------
cd code
docker compose exec db mariadb -ushop -pshoppw opencart -e \
  "SELECT COUNT(*) FROM oc_customer; \
   SELECT COUNT(*) FROM oc_session; \
   SELECT COUNT(*) FROM oc_order; \
   SELECT COUNT(*) FROM oc_customer_ip;"

# --- 2. Find the most sensitive single row ----------------------------
# Not the biggest table. The one whose leak would do most harm.
# Name it and say why in one sentence.

# --- 3. Decide a retention period for each ----------------------------
# Three columns: what, how long, why. "Forever" needs a reason too.

# --- 4. Build the dark pattern, then look at it -----------------------
python m12_discounts.py --sortorder
# Read the two totals. Write the sentence you would have to say to
# the customer to explain the second one.

# --- 5. Put it back ---------------------------------------------------
python m12_discounts.py --restore

# --- 6. Try your checkout with the keyboard only ----------------------
```

```
# No mouse, no trackpad. Tab and Enter. Get to a completed order.
# Write down where you got stuck.

# --- 7. Check your images ---------------------------------------
curl -s "http://localhost:8090/index.php?route=product/category&path=20" \
  | grep -o '<img[^>]*>' | grep -c 'alt='
curl -s "http://localhost:8090/index.php?route=product/category&path=20" \
  | grep -c '<img'
# Two numbers. They should be equal.

# --- 8. Write your terms ----------------------------------------
# One page a customer could read: who you are, what you sell, the
# price including tax, delivery, how to cancel, how to complain, and
# what you do with their data. Then check your shop does what it says.
```

What to notice. Step 8 is the exercise. Almost every shop's published terms describe a shop that does not exist, because nobody checked the sentences against the software — and this course has spent twenty-one chapters learning how to check.

Checkpoint — Test Yourself

1. A shop moves its coupon line after its tax line and collects 1.8% more on every discounted order. Nothing was concealed and every figure is correct. Argue whether this is a dark pattern, state what would change your answer, and say what you would do if you found it in a shop you had inherited.
2. Your shop holds 645 session rows and 6 orders. Rank the two tables by risk, justify the ranking, give a retention period for each with your reasoning, and say which one you would be more reluctant to delete and why.
3. A client asks you to store card numbers "because our competitor does". Write the reply you would send: the refusal, the reason in terms of consequence, the alternative, and what you would do if the client insisted.

Chapter Summary

- The Electronic Transactions Ordinance 2002 is what makes an online order a contract — and makes your published terms binding on you. The order record is the contract, which is why it copies its data.
- PECA 2016 makes unauthorised access an offence; the E-Commerce Policy 2019 sets the framework; FBR administers the tax.
- **Consumer protection in Pakistan is provincial**, with separate Acts and authorities, so "the consumer protection law" does not exist as a single thing.
- **Pakistan has no comprehensive data protection Act in force.** That means the law will not stop you, not that nothing binds you — an uncomfortable position rather than a comfortable one.
- This course's own measurements are the data inventory: 645 session rows from robots, addresses and telephone numbers on guest orders, a purchase history per named person, an IP on every customer, and — before hardening — an error log anyone could read.
- Ask of each: why do we have it, how long do we need it, and what happens if it leaks. Rank by harm, not volume. You cannot lose what you did not keep.
- A dark pattern is an arrangement, not a lie, and Chapter 12 built one by moving a single integer. Test by whether you could explain the arrangement out loud to the customer it affects.

- Four accessibility measures cost nothing at build time and cannot be retrofitted cheaply. The keyboard-only checkout is the one that usually fails.
- Refuse clearly, give the consequence rather than the principle, and always offer the nearest thing you can do.

Review Questions

1. **(MCQ)** Consumer protection legislation in Pakistan is: (a) federal only; (b) provincial; (c) governed by PECA 2016; (d) not yet enacted anywhere.
2. **(MCQ)** What makes an electronic order legally enforceable in Pakistan? (a) PECA 2016; (b) the E-Commerce Policy 2019; (c) the Electronic Transactions Ordinance 2002; (d) the shop's terms.
3. **(Short)** Explain why an order copies its prices and addresses rather than referring to them, in legal rather than technical terms.
4. **(Short)** Give the one-sentence test for a dark pattern, and apply it to a countdown timer that resets when the page is reloaded.
5. **(Short)** Why is "we have no data protection Act" a reason for more care rather than less?
6. **(Applied)** Write the data retention schedule for a shop taking 50 orders a day: every table holding anything about a person, how long it is kept, the reason, what deletes it, and who checks. Mark anything you would need advice on rather than deciding yourself.
7. **(Applied)** Your employer asks you to implement a checkout that pre-ticks an optional insurance product. Set out your analysis: what the law here does and does not say, what the one-sentence test gives, what you would propose instead, what you would do if overruled, and at what point you would decline to build it at all.